PLANET IT part of TalkTalk Business

Security Maturity Assessment

Acme Corp

Prepared by Bradley Collis

September 2026



Microsoft Solutions Partner Modern Work

Microsoft Solutions Partner Security

Microsoft Solutions Partner Infrastructure Azure

SOPHOS PARTNER OF THE YEAR 2025

Sophos Platinum Partner

THE SUNDAY TIMES Best Places to Work 2026 MEDIUM ORGANISATION

QSL ISO 27001 Information Security Management Certification

CYBER ESSENTIALS CERTIFIED PLUS

Acme Corp – Executive Summary

Acme Corp completed a cybersecurity maturity assessment with Planet IT. The review considered the organisation's current security architecture, operational dependencies, security culture and resilience arrangements through a consultant-led discussion and supporting assessment notes. The assessment provides a point-in-time view based on the information shared during the consultation; it is not a certification audit or independent technical validation of every control.

- **Identity & Access Management (IAM):** An evaluation of authentication controls, MFA enforcement, and alignment with zero-trust principles to protect user credentials.
- **Endpoint Protection:** The posture of device-level security, malware defence, and the restriction of local administrator privileges across the estate.
- **Network & Perimeter Security:** An assessment of firewall architectures, network segmentation, and secure remote access controls for physical and virtual locations.
- **Email & Collaboration Security:** Defences against phishing, business email compromise and malicious content across Google Workspace and connected SaaS services.
- **Cloud & Infrastructure Security:** The security configuration and workload protection mechanisms applied to public cloud environments and on-premises server infrastructure.
- **Security Monitoring & Response (MDR/SOC):** The organisation's capability to actively detect, investigate, and remediate threats on a 24/7 basis using cross-domain telemetry.
- **Security Validation & Testing:** The frequency and efficacy of proactive offensive testing, including vulnerability scanning and internal/external penetration testing.
- **Security Culture & Awareness:** An analysis of human-centric risk, evaluating the maturity of user coaching, phishing simulations, and general security behaviour.
- **AI Governance & Control:** The strategies and controls in place to identify, govern and control access to approved AI systems as well as identification and control of shadow AI usage.
- **Governance, Risk & Compliance (GRC):** The strategic alignment of current controls with target compliance frameworks (e.g., ISO 27001, Cyber Essentials) and the overarching protection of critical business assets.

This report summarises the estimated security maturity observed across Acme Corp's current environment. It identifies areas where existing controls are working effectively, highlights gaps that may increase operational or commercial risk, and sets out proportionate recommendations to support internal prioritisation, budget planning and the MDR business case.

Security Rating

Overall indicative weighted score: 60/100 – Established, with targeted gaps requiring validation
This score is a consultant-led, point-in-time maturity judgement based on the assessment discussion and supporting notes. It is not a certification score or an independently tested technical rating. The weighting gives greater emphasis to controls that affect operational continuity, incident response, identity compromise and client-data exposure; individual domain scores should therefore be used to prioritise assurance work rather than as precise measures of control effectiveness.



Security Rating Snapshot

Executive measure	Assessment
Overall score	60/100
Maturity rating	Established
Direction of travel	Positive, with several established controls already in place.
Primary strengths	Fortinet-managed perimeter, Webroot EDR, Kanji/Iru patching, Veeam and QNAP backup architecture, Cyber Essentials Plus activity, annual penetration testing, Google SSO adoption and internal alert handling.
Primary gaps	FTP MFA, vulnerability scanning between annual tests, administrator-password renewal, incident-response testing, data classification, Google Workspace backup assurance, formal phishing simulation and out-of-hours monitoring capacity.
Board-level takeaway	Acme Corp has a credible security baseline, but assurance is uneven. The immediate priorities are out-of-hours response coverage, secure file-transfer authentication, vulnerability visibility, incident-response rehearsal and cloud productivity recovery testing. These actions validate and strengthen existing controls before any wider replacement programme is considered.

Weighted Maturity Table

Area	Weight	Indicative score	Weighted contribution	Rationale
Identity and privileged access	15%	60	9.0	MFA and SSO are broadly used, but FTP MFA and local administrator password renewal remain material gaps.
Endpoint and patch management	15%	65	9.8	Webroot EDR and Kanji/Iru provide a useful baseline, but staged macOS patching can delay the intended 14-day target and more mature endpoint protection technologies should be considered, alongside MDR solutions
Network and perimeter	10%	65	6.5	Fortinet and MPLS are managed by Spire, but geo-locking, FTP exposure and vulnerability visibility require validation.
Backup and recovery	15%	68	10.2	Veeam, QNAP and off-site replication are positive, but Google Workspace recovery assurance needs confirmation.
Monitoring and response	15%	50	7.5	Freshdesk and Webroot alerts are reviewed internally, but there is no dedicated 24/7 SOC or MDR capability.
Vulnerability management and testing	10%	55	5.5	Cyber Essentials Plus and annual penetration testing are positive, but there is no dedicated vulnerability-scanning capability between tests.
Data, SaaS and AI governance	10%	55	5.5	AI policy, Google SSO and SaaS awareness are developing, but classification, shadow IT and AI monitoring need maturing.
Governance, insurance and resilience	10%	60	6.0	Cyber insurance and documentation are in place, but tabletop testing, downtime modelling and response ownership need validation.

Maturity Band Legend

Score range	Rating	Meaning
0–39	Reactive	Controls are limited, informal or largely untested.
40–59	Developing	Core controls exist, but coverage, ownership or assurance is inconsistent.
60–74	Established	Most controls are in place, with targeted gaps requiring validation or improvement.
75–89	Managed	Controls are repeatable, monitored and regularly tested.
90–100	Optimised	Controls are mature, measured, continuously improved and independently validated.

The score should be treated as a prioritisation tool rather than a formal audit outcome. It helps compare relative maturity across domains and identify where assurance effort should be focused first.

Critical Findings

For Acme Corp, the immediate concern is how quickly an incident can be recognised, contained and managed without interrupting customer delivery. Existing endpoint, perimeter and backup controls provide a foundation; the most pressing gaps are out-of-hours response, the secure file-transfer authentication exception and untested recovery decisions. The priorities below focus on those gaps rather than wholesale replacement.

Severity	Priority requirement	Business exposure	Recommended next step
RED	**Out-of-hours monitoring and response** Working-hours review is in place; 24/7 investigation coverage is not.	Overnight or weekend incidents may take longer to identify and contain, increasing downtime and customer impact.	• Validate available telemetry and response authority. • Compare internal, retained-response and MDR options.
RED	**Incident and recovery readiness** Plans exist but have not been exercised with directors.	Unclear roles and recovery order could prolong disruption to production and customer delivery.	• Run an executive tabletop exercise. • Agree decision owners, escalation routes and recovery priorities.
RED	**FTP and privileged-access controls** FTP remains a material MFA exception; administrator-password renewal is informal.	Compromised credentials could expose customer files and commercially sensitive production data.	• Secure or replace the FTP route. • Formalise administrator-password renewal and access reviews.
AMBER	**Vulnerability visibility** Annual testing is not supported by continuous or scheduled scanning.	Weaknesses may remain undetected between assurance points across endpoints, ESXi and external services.	• Scope dedicated vulnerability scanning. • Track remediation by exploitability and business criticality.
AMBER	**Customer-data governance** Formal classification and DLP controls are not yet in place.	Customer files may be handled inconsistently across the client-facing portal, approved external file-sharing services, the internal file-transfer service and cloud storage.	• Define practical data classifications and approved sharing routes. • Assess targeted DLP controls against business need.
GREEN	**AI governance** Policy and managed business accounts are already in place.	Residual exposure is personal or unapproved AI use involving company or customer data.	• Complete the shadow-IT and prohibited-data rules. • Test available application and web-control visibility.

Indicative Solutions

Severity	Priority requirement	Indicative solution	Why this fits Acme Corp	Cost band
RED	**Out-of-hours monitoring and response**	**Sophos MDR Complete** Google Workspace and Fortinet integrations; readiness, onboarding and service governance delivered by Planet IT.	Provides analyst-led 24/7 monitoring and cross-tool investigation. Discovery should confirm supported telemetry, the effect on the current Webroot deployment, escalation routes and permitted response actions.	**High / TBC** Recurring managed service; final cost depends on users, servers, integrations and response mode.
RED	**Incident and recovery readiness**	**Planet IT Cyber Incident and Recovery Readiness Package** Executive tabletop exercise and response-plan review	Tests director-level decisions, insurer and supplier escalation, customer communications and recovery order.	**Medium initially; High if backup licensing is added** Fixed professional services
AMBER	**Vulnerability visibility**	**Sophos Managed Risk powered by Tenable** Remediation reviews delivered by Planet IT.	Adds scheduled discovery and risk-based prioritisation between annual penetration tests across endpoints, servers, ESXi hosts and externally exposed services.	**Medium to High / TBC** Depends on asset count, scan coverage and review frequency. Relies on Sophos MDR implementation
GREEN	**AI governance**	**Sophos AI Defense**	Provides visibility of AI tools, agents and shadow-AI activity; assesses risk using identity, permissions, behaviour, data exposure and location; and applies policy guardrails to reduce unsafe use.	**Medium to High / TBC** Depends on Sophos platform adoption, licensed users and devices, required control coverage, onboarding and policy configuration.

Cost bands are indicative planning categories rather than quotations. Low denotes a short advisory or review activity; Medium denotes a scoped implementation, workshop or technical validation exercise; High denotes recurring managed-service, licensing or multi-stage implementation cost. TBC indicates that supplier pricing, asset scope, telemetry or design decisions are required before a reliable estimate can be produced.

Recommended next step: approve a scoped discovery and remediation planning exercise for the identified workstreams. This should confirm costs, delivery sequencing, ownership and decision points for funded change.

Main Findings

The main findings and recommendations of the report are:

1. Out-of-hours monitoring and response coverage

Finding: Acme Corp's IT team reviews user reports and available alerts from Freshdesk, Webroot and Google Workspace, but there is no dedicated analyst-led monitoring service outside normal working hours. Investigation may therefore require the team to gather evidence from separate tools and coordinate escalation without immediate specialist support.

Risk: A material incident affecting customer files or production systems could take longer to identify and contain overnight or at weekends. Given Acme Corp's low tolerance for downtime, the priority is to validate the required coverage, response authority and available telemetry.

Remediation actions: Confirm available Webroot, Fortinet, Google Workspace, Freshdesk, email and cloud telemetry; define out-of-hours contacts and containment authority; compare internal, retained-response and MDR options against the agreed requirement; and use the tabletop exercise and downtime-cost model to support the investment decision.

2. Incident response, disaster recovery and downtime tolerance

Finding: Acme Corp has incident-response documentation in progress, cyber insurance and established support relationships, including Planet IT. The consultation did not confirm that the plan has been exercised with directors and business decision-makers. A complete shutdown would significantly disrupt production.

Risk: Unclear responsibilities and untested escalation could delay containment, customer communication, insurer engagement and recovery. The core business-management system, automation platform, client-facing portal, file servers, cloud productivity services and site infrastructure all support job delivery and client relationships.

Remediation actions: Review the incident-response and disaster-recovery plans; assign containment, communication, insurer, supplier and recovery decisions; run an executive tabletop exercise; agree recovery order for critical systems; and calculate downtime costs to inform the MDR business case.

3. Vulnerability visibility between assurance points

Finding: Acme Corp undertakes Cyber Essentials, Cyber Essentials Plus and annual penetration testing, but has no dedicated vulnerability-scanning platform. Previous audit activity identified issues that device-management tooling had not detected; endpoint and device-management data do not provide the same depth of vulnerability discovery.

Risk: Vulnerable components or configurations may persist between formal reviews, particularly across staged macOS updates, ESXi 7 hosts, file servers and internet-facing services.

Remediation actions: Scope scanning across endpoints, servers, ESXi hosts and external services; rank findings by exploitability and business criticality; record owners and closure evidence; and align reporting with Cyber Essentials Plus and ISO 27001 planning.

Simulated attack of current infrastructure

Disclaimer: this is a fictional breach scenario using threat-informed assumptions mapped to Acme Corp's current technology stack and observed maturity. It is intended to illustrate credible risk paths and improvement priorities only.

Initial access through email and customer file sharing

A credible attack against Acme Corp would most likely begin with a phishing email or fraudulent file-sharing request linked to a live customer job, artwork approval, production query or supplier workflow. The attacker sends a message that appears to come from a customer, colleague or trusted supplier and directs the recipient to a convincing cloud-productivity sign-in page, shared-document prompt or file-transfer notification.

If the user enters credentials or approves a malicious session, the attacker gains access to a legitimate account rather than deploying malware immediately. This allows activity to blend into normal customer and production workflows.

Likely attacker activity would include:

- capturing Google Workspace credentials or an authenticated session;
- reviewing mailbox content for customers, suppliers, invoices and active production jobs;
- identifying shared Google Drive content and customer-file links;
- creating forwarding rules or other persistence where permissions allow;
- testing access to the client-facing portal, approved external file-sharing services, the internal file-transfer service or connected SaaS services;
- using the trusted account to send further phishing or file-sharing requests.

Relevant MITRE ATT&CK techniques include:

- Spearphishing Link (T1566.002);
- Valid Accounts (T1078);
- Steal Web Session Cookie (T1539);
- Account Discovery (T1087);
- Email Collection (T1114);
- Data from Cloud Storage (T1530).

Google SSO and MFA already reduce the likelihood of straightforward password-only compromise across supported services. The more credible residual risk is that a user approves a convincing sign-in or file-sharing request, an authenticated session is misused, or the attacker reaches a service that does not inherit the same controls. The internal FTP server is particularly relevant because it remains outside the broader MFA model.

Progression through customer and production dependencies

Once access is established, the attacker would use mailbox and file-sharing information to identify high-value customer data, current production activity and operational dependencies. Cloud file storage, the client-facing portal, internal file servers and file-transfer workflows are the most likely initial targets because they support customer collaboration and file exchange.

Likely activity at this stage would include:

- searching email for customer names, active projects and transfer instructions;
- accessing shared files through the compromised user's existing permissions;
- reusing legitimate links or credentials to avoid immediate detection;
- probing FTP and externally hosted services;
- attempting to reach the MIS system, automation server or file servers through an IT or privileged account;
- staging customer files for exfiltration through a web or cloud service.

Relevant MITRE ATT&CK techniques include:

- Cloud Service Discovery (T1526);
- Remote Services (T1021);
- File and Directory Discovery (T1083);

- Data from Local System (T1005);
- Exfiltration Over Web Service (T1567);
- Account Manipulation (T1098).

The likely business impact would depend on the account compromised and the time to detection. A contained mailbox incident could still expose customer correspondence, shared links and commercially sensitive production information. Compromise of an IT account or administrator workstation could extend the incident towards virtualised workloads, file servers, backup infrastructure or site services. Disruption to core business-management systems, automation platforms, the client-facing portal or file servers could delay job delivery and create immediate customer-management and contractual pressure.

Recovery considerations

Acme Corp's on-premises and off-site backup arrangements provide an established recovery foundation for on-premises workloads and file-server data. The principal uncertainty is whether restores have been tested against the scenarios that matter most and whether recovery order has been agreed with the business.

Google Workspace data is not independently backed up to another cloud platform. Native retention and version history may support recovery in some cases, but they may not provide the required assurance if data is deleted, altered or shared before the incident is identified. Recovery requirements for Gmail, Drive and Shared Drives should therefore be confirmed and tested before a dedicated backup service is selected.

How Sophos MDR could assist

Sophos MDR could provide analyst-led monitoring and investigation across the telemetry made available to the service. Its value in this scenario would be the ability to connect low-confidence indicators from different sources and determine whether the event is limited to one account or forms part of a wider compromise.

Relevant detection signals could include:

- unusual Google Workspace sign-ins or session activity;
- atypical mailbox or Drive access;
- suspicious endpoint behaviour associated with credential theft;
- unexpected administrator actions;
- unusual outbound connections or firewall events;
- access to customer files outside normal working patterns;
- evidence that a reported phishing message led to wider account or endpoint activity.

If compromise were confirmed, the service could support triage, scope assessment and containment in line with the agreed response mode. Actions could include isolating a supported endpoint, guiding credential resets and session revocation, reviewing suspicious email and cloud activity, supporting firewall-led containment and preserving evidence for directors, insurers and suppliers.
An MDR service would not replace Acme Corp's ownership of production decisions, customer communications or supplier coordination. Its effectiveness would also depend on the telemetry available from the cloud productivity suite, perimeter controls, email services and endpoints, together with any endpoint-platform changes required during onboarding.

Recommended improvements highlighted by the scenario

The scenario supports six practical priorities:

- validate out-of-hours monitoring requirements and the telemetry available to Sophos MDR;
- secure or replace the internal FTP transfer route;
- run an executive incident-response and recovery tabletop exercise;
- introduce scheduled vulnerability scanning between annual tests;
- define customer-data classifications and approved sharing routes;
- test Google Workspace and critical-system recovery against agreed business priorities.

Together, these measures would reduce the likelihood of a trusted-account compromise progressing unnoticed, improve containment outside normal working hours and give Acme Corp clearer recovery options if customer or production data were affected.

Executive Commentary

Acme Corp has established controls across its estate: Cyber Essentials and Cyber Essentials Plus activity, annual penetration testing, endpoint detection and response, device management and patching, and backup protection for on-premises workloads. The assessment identifies where those controls need stronger validation and where a small IT team would benefit from additional response capacity. The leading operational gap is 24/7 monitoring. User reports and available alerts are reviewed internally, but an incident outside normal working hours could require the team to piece together endpoint, firewall, identity and email evidence before deciding what to contain. MDR is therefore a red-priority workstream, subject to confirming telemetry, escalation routes and the response authority it would have. The same exercise should test who makes business decisions during an outage and when insurers, suppliers and customers are contacted. File-transfer authentication, vulnerability visibility, data classification and cloud-productivity recovery also warrant focused work. Acme Corp can address these through a secure-transfer decision, dedicated scanning, clear customer-file handling rules and representative recovery tests. The roadmap sequences that work alongside an executive tabletop exercise and downtime-cost calculation, so investment decisions rest on evidence rather than a general call to replace existing tools.

Compliance and Framework Alignment

Current position: Acme Corp maintains Cyber Essentials and Cyber Essentials Plus activity and is working towards ISO 27001. The assessment did not identify PCI as an applicable requirement, and this report should not be read as a formal certification audit. The immediate compliance focus should be to evidence existing controls, close known gaps around file-transfer MFA, privileged-account hygiene, vulnerability visibility, data classification and incident-response testing, and align the improvement plan with ISO 27001 readiness.

As part of the consultation, the current control position has been mapped against Cyber Essentials, Cyber Essentials Plus and ISO 27001 planning priorities. These areas should be read as readiness and assurance priorities rather than certification findings.

Framework area	Relevant expectation	Current gap / consideration	Recommended focus
Cyber Essentials: User access control and MFA	User and administrative access should be controlled through unique accounts, least privilege and MFA for cloud services and externally accessible services wherever available.	MFA is broadly used across Google Workspace, SSO-enabled services and SaaS applications where supported. The internal FTP server remains a significant MFA exception, and administrator-password renewal for IT-managed local accounts is not yet formalised.	Address the FTP MFA gap or replace FTP with a more controlled transfer model. Document SaaS MFA coverage, record approved exceptions, formalise local administrator-password renewal and include privileged-access review within the improvement register.
Cyber Essentials: Secure configuration	Devices, services and externally reachable systems should be securely configured, unnecessary services removed or restricted, and administrative access appropriately controlled.	Fortinet firewall infrastructure is managed by Spire, and end users have limited local access. Assurance is still required around FTP exposure, geo-locking, externally exposed services, local administrator account	Validate firewall geo-locking and exposed services with Spire, review FTP access restrictions, document ESXi 7 risk and workload criticality, and maintain evidence of secure configuration

		hygiene and legacy ESXi 7 hosts retained for licensing reasons.	decisions and accepted exceptions.
Cyber Essentials: Security update management	Supported operating systems and applications should be patched within defined timescales, with unsupported or legacy systems removed, upgraded or risk managed.	Kanji/Iru is used for application deployment, operating-system patching and application patching. macOS updates are staged to reduce disruption, which can affect the intended 14-day patching target. Legacy ESXi 7 hosts remain in use for licensing reasons.	Maintain patch-compliance reporting across Mac, Windows and server workloads. Record staged rollout rationale, document exceptions and risk acceptance, review ESXi lifecycle exposure, and use vulnerability scanning to identify issues not visible through patch status alone.
Cyber Essentials: Malware protection	In-scope devices should use active malware protection or an equivalent application-control approach, with protection kept active and appropriately managed.	Webroot EDR is deployed across end-user devices, but low alert volume creates some uncertainty over visibility. Application-control capability has not yet been fully tested for unauthorised tools or shadow-AI usage.	Confirm Webroot coverage and alerting across the endpoint estate, validate reporting and escalation paths, test application-control capability where appropriate, and confirm whether endpoint telemetry can support MDR investigation.
Cyber Essentials Plus: Technical validation and evidence	Controls should be evidenced through technical testing, including validation of patching, malware protection, secure configuration and externally exposed services.	Acme Corp undertakes Cyber Essentials Plus and annual penetration testing, but no dedicated vulnerability-scanning platform is currently in place. Previous audit activity identified issues that were not detected by device-management tooling, indicating that endpoint and device-management controls do not provide complete vulnerability visibility.	Evaluate a dedicated vulnerability-scanning capability covering endpoints, servers, ESXi hosts, file servers and internet-facing services. Track remediation through a register with owners, target dates, exception rationale and closure evidence.
ISO 27001 planning: Asset and risk ownership	Information assets, system owners, risks, controls and treatment actions should be identified, documented and reviewed through a repeatable governance process.	Critical systems have been identified, including core business-management and automation systems, the client-facing portal, file servers, cloud productivity services and site infrastructure. A consolidated asset, system-owner and improvement register is not yet fully established.	Create a security improvement and risk register covering critical assets, control owners, evidence, dependencies, target dates, accepted risks and closure evidence. Use this register to support ISO 27001 planning and leadership reporting.
ISO 27001 planning: Data classification and	Information should be classified and handled according to sensitivity, business impact and	Acme Corp does not yet have a formal data classification model or implemented DLP capability. Customer	Define practical classifications for customer files, production data and commercially sensitive information.

information handling	contractual or regulatory consequences.	information is shared through the client-facing portal, approved external file-sharing services, the internal file-transfer service and cloud storage.	Confirm approved sharing routes, prohibited data handling, DLP options and incident severity criteria based on business impact.
ISO 27001 planning: Incident response and business continuity	Incident-response and recovery arrangements should define roles, escalation paths, communications, supplier engagement and recovery responsibilities, and should be tested periodically.	Incident-response documentation is in progress, but the plan has not yet been validated through a practical exercise involving IT, directors and business decision-makers. Recovery expectations for critical systems and Google Workspace require clearer validation.	Refresh incident-response and disaster-recovery documentation, define decision ownership, insurer and supplier escalation routes, recovery sequencing and communications responsibilities, and run a board-level tabletop exercise using a realistic outage, ransomware or data-access scenario.
ISO 27001 planning: Supplier and third-party assurance	Supplier dependencies should be understood, contractual and operational responsibilities should be clear, and incident-notification expectations should be defined.	Key dependencies include a managed network and firewall provider, cloud productivity and hosting platforms, endpoint and device-management tooling, external file-sharing and HR SaaS services, and Planet IT support during incidents. Supplier assurance and incident-notification expectations require clearer documentation.	Document critical suppliers, service owners, access routes, data sensitivity, incident-notification expectations and recovery dependencies. Include supplier escalation in incident-response and disaster-recovery exercises.
ISO 27001 planning: AI governance and shadow IT	Approved AI use, prohibited data types, ownership and monitoring expectations should be defined and communicated.	An AI usage policy and business-account model are already in place, with Gemini, Claude, historic ChatGPT business accounts and Adobe generative-AI access managed or monitored to differing degrees. The remaining concern is personal or unapproved AI usage involving company or customer data.	Complete the shadow-IT policy, define approved AI tools and prohibited data types, communicate expectations around personal AI accounts, test application-control capability and assess whether future AI monitoring provides measurable control value.

The Cost of Inaction

If the identified gaps are not addressed, a material incident could take longer to understand, contain and recover from. The most credible financial exposure is associated with interrupted production, delayed job delivery, customer communication, specialist response, recovery activity and possible contractual consequences.

For initial planning, the report uses an indicative range for a one-day disruption affecting core business-management systems, automation platforms, the client-facing portal, file servers or cloud productivity services. A multi-day incident involving customer-data exposure, file-integrity concerns or prolonged operational disruption could result in materially higher costs once external response, legal review, insurer engagement and client assurance are included. These values are planning

assumptions, not a formal loss estimate.

Acme Corp should validate them using turnover, gross profit, employee costs, production capacity, contractual commitments and the recovery dependencies of critical workflows. The principal cost drivers are investigation time, lost production, supplier and specialist support, recovery uncertainty, customer assurance, contractual consequences and management time. The recommended control improvements should be assessed against their ability to reduce the likelihood, duration or cost of those outcomes.

Overview of Current Environment

Organisational Profile	Details
Industry	Creative production / brand services / customer file handling
Headcount	Medium-sized organisation
Endpoints / Servers	A mid-sized mixed-device estate with virtualised workloads and file-server infrastructure across multiple sites.
Operating Systems	Predominantly macOS, supported by a smaller Windows estate.
Sites and infrastructure	Multiple UK locations and a hosted data-centre environment connected through a managed wide-area network.
Cloud Infrastructure	A cloud productivity suite is the primary collaboration platform. Web workloads are moving to a public-cloud hosting provider, and cloud object storage supports a database workload. A secondary productivity platform is used to a limited extent for desktop applications and selected authentication needs.
Microsoft Licensing	Limited Microsoft 365 usage for productivity applications and selected authentication requirements.
In-House Security Coverage	Internal IT-led monitoring during normal working hours, with Freshdesk receiving user reports and some Webroot alerts. No dedicated 24/7 SOC or MDR service is currently in place.
Target Compliance	Cyber Essentials, Cyber Essentials Plus and ISO 27001 planning.
Crown Jewels	Core business-management and automation systems, the client-facing portal, file services, cloud productivity services, customer file repositories and site infrastructure.
Current Technology	**Details**
MDR / SOC Provider	None
Endpoint Security	Webroot EDR across end-user devices.
Endpoint Technology	EDR capability with alerting into Freshdesk.
MDM / Patch Management	Kanji/Iru for MDM, application deployment, operating-system patching and application patching.
Network Firewall	Fortinet firewall infrastructure managed by Spire.
Identity & Access	Google Workspace and Google SSO for SaaS where practical; limited Microsoft 365 authentication usage.
Email Security	Google Workspace native protections; no separate gateway such as Mimecast or Barracuda currently deployed.
Security Culture	Security newsletters and user alerts are in place. Formal recurring phishing simulation has not been run recently.

Internal SOC Team	No dedicated internal SOC; monitoring is handled by the internal IT team through existing tools and processes.
Penetration Testing	Annual penetration testing takes place as part of the assurance cycle.
Vulnerability Scanning	No dedicated vulnerability-scanning platform currently in use. Webroot and Kanji/Iru provide partial visibility but do not replace deeper vulnerability scanning.

Risk, Compliance and Posture	Details
Backups Structure	Veeam Backup and Replication performs local backups to QNAP storage and off-site backups to another site. File servers also use QNAP Hybrid Backup Sync, local and off-site mirror backups and synchronisation to Google Drive.
SaaS Backups	Google Workspace data is not independently backed up to another cloud platform and currently relies on Google's native controls and version history.
Remote Access Strategy	Remote users connect via VPN. The internal file-transfer service remains a specific access-control concern because MFA is not currently supported or enabled.
Incident Response Readiness	Incident-response documentation is in progress, but the plan has not yet been clearly validated through a practical exercise involving IT, directors and business decision-makers.
MFA Status	MFA is broadly used across Google Workspace, SSO-enabled services and SaaS applications where supported. The internal FTP server remains a significant MFA exception.
Patching Strategy	Kanji/Iru supports application deployment, operating-system patching and application patching. macOS updates are staged to reduce disruption, which can affect the intended 14-day patching target.
Cyber Insurance Status	Active policy in place. Precise coverage and premium need confirmation with the CFO.
Outage Tolerance	Very low. A complete shutdown would significantly disrupt operations. Formal system-level RTO and RPO targets have not yet been validated.

Detailed Assessment

Domain: Identity & Access

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with established controls in several areas.
Technical Analysis	The organisation uses Google Workspace as the primary identity and productivity platform, with SSO used for SaaS applications wherever practical and MFA enabled where supported. End users have limited local access, while IT retains credentials for local administrator accounts and can manage access through Active Directory or Kanji/Iru. The main identity and privileged-access gaps are the lack of MFA on the internal FTP server and the absence of a formal administrator-password renewal policy for managed devices.
Business Impact & Risk	A compromised identity, unmanaged privileged account or file-transfer access path could expose customer files, commercially sensitive production data or operational systems. The risk is particularly relevant because Acme Corp uses several data-sharing channels and supports customers where supply-chain confidence is commercially important.
Critical Gaps	• MFA is not currently available or enabled on the internal FTP server. • Local administrator-password renewal requires formalisation. • SaaS SSO and MFA coverage should continue to be documented and reviewed. • Exceptions should be recorded with an owner, rationale and review date.
Zero-Cost Quick Wins	• Document all SaaS applications, authentication method, MFA status and business owner. • Create a local administrator-password renewal process for IT-managed accounts. • Confirm whether FTP access can be restricted by user, location, IP range or another compensating control. • Maintain an exception register for services that cannot support SSO or MFA.
Recommended Solutions	• Address the FTP MFA gap or replace FTP with a more controlled transfer model. • Review identity and administrator-access controls across Google Workspace, Active Directory, Kanji/Iru and SaaS services. • Evaluate whether identity-threat detection or MDR telemetry would improve visibility of suspicious sign-ins and account activity. • Include privileged-account review and FTP access risk in the incident-response tabletop.

Strategic Remediation Rationale	Google SSO and MFA already cover many supported services. Closing the FTP authentication exception, renewing IT-managed administrator passwords on a defined schedule and recording SaaS access exceptions would strengthen the remaining access controls without rebuilding the identity platform.
Partnership Recommendations	Planet IT can support authentication review, file-transfer risk assessment, administrator-account hygiene, SaaS MFA discovery and identity-related MDR readiness. Acme Corp would retain ownership of account policy decisions, exception approval and operational change scheduling.

Domain: Information Protection

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Customer files and production information move through the client-facing portal, approved external file-sharing services, an internal file-transfer service and, in some cases, cloud storage. Acme Corp has not yet formalised a data classification model or implemented DLP controls. Clear rules for each sharing route would help staff recognise which information needs tighter handling and give IT a basis for reviewing access and alerts.
Business Impact & Risk	Without a defined classification and sharing model, teams may treat customer and production data inconsistently. A leak, accidental disclosure or personal AI upload could affect client confidence, contractual outcomes and renewal discussions, even if the technical incident is contained quickly.
Critical Gaps	• No formal data classification model is currently in place. • DLP controls are not currently deployed through Fortinet, Webroot or Google Workspace. • External sharing routes require clearer control expectations. • Customer and supply-chain data impact should be defined by business consequence, not only file type.
Zero-Cost Quick Wins	• Define a small number of practical classifications for customer files, production data and business-sensitive information. • Confirm approved sharing routes and when each should be used. • Document prohibited handling, including use of personal AI accounts for company or customer data. • Review existing policies governing the client-facing portal, approved external file-sharing services, the internal file-transfer service and cloud storage.
Recommended Solutions	• Assess proportionate DLP capability through Google Workspace, endpoint, firewall or future security tooling. • Align data classification with ISO 27001 planning and incident-response playbooks.

	• Review whether external sharing logs and alerts can support investigation. • Include customer-file exposure scenarios in tabletop exercises.
Strategic Remediation Rationale	A lightweight classification model would help Acme Corp make more consistent decisions about customer data, sharing methods, AI usage and incident severity. It would also support ISO 27001 planning and provide a clearer basis for deciding whether DLP investment is required.
Partnership Recommendations	Planet IT can support data classification workshops, external sharing review, DLP options assessment and incident scenario design. Acme Corp would retain ownership of data-handling policy, customer requirements and business-risk acceptance.

Domain: SaaS Governance

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with established SSO and MFA foundations across supported SaaS services.
Technical Analysis	Acme Corp uses a cloud productivity suite as its main productivity platform and applies SSO to SaaS applications where practical; MFA is enabled where supported. A current application register would make ownership, authentication, MFA capability, data sensitivity and offboarding requirements easier to check. It would also help identify personal AI accounts and other unapproved SaaS use.
Business Impact & Risk	Untracked SaaS applications, inconsistent MFA coverage or incomplete offboarding could expose customer files, production data, HR information or operational workflows. The risk is heightened where personal or unapproved AI tools are used outside centrally managed business accounts.
Critical Gaps	• SaaS application ownership and MFA status require ongoing documentation. • Offboarding and access-review evidence should be strengthened across SaaS applications. • Shadow IT and unsupported AI-linked SaaS usage remain visibility concerns. • SaaS data sensitivity and business criticality are not yet consistently classified.
Zero-Cost Quick Wins	• Create a SaaS register covering owner, authentication method, MFA status, data type and exit process. • Prioritise applications that can use Google SSO and MFA. • Record approved exceptions for applications that cannot support SSO or MFA. • Include SaaS access review in joiner, mover and leaver processes.

Recommended Solutions	• Maintain a recurring SaaS access and ownership review. • Align SaaS governance with the ISO 27001 improvement register. • Review Google Workspace, browser, endpoint and firewall signals for shadow SaaS or unapproved AI use. • Consider third-party identity, CASB or MDR telemetry improvements only where native controls cannot provide sufficient visibility.
Strategic Remediation Rationale	SSO and MFA provide a foundation for supported SaaS services. A named owner and periodic access review for each application would help Acme Corp demonstrate coverage, manage exceptions and close access promptly when users leave or change roles.
Partnership Recommendations	Planet IT can help inventory SaaS applications, check SSO and MFA coverage, and design access reviews. Application approval, joiner–mover–leaver decisions and risk acceptance remain with Acme Corp.

Domain: Asset Assurance

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with established endpoint and infrastructure knowledge but incomplete exposure assurance.
Technical Analysis	Acme Corp manages a mid-sized, predominantly macOS endpoint estate with a smaller Windows environment. Its UK sites include virtualised workloads and file servers; some services are moving to a hosted data-centre environment and web workloads are moving to a public-cloud provider. Dedicated vulnerability scanning and a combined record of assets, exposure and remediation would make it easier to assess risk across those environments.
Business Impact & Risk	If asset and exposure data is incomplete, vulnerable systems may remain unremediated between annual testing points. This is particularly relevant for staged macOS patching, legacy ESXi 7 hosts, file servers, DigitalOcean-hosted workloads and internet-facing services that support customer file exchange or production workflows.
Critical Gaps	• No dedicated vulnerability-scanning platform is currently in use. • ESXi 7 hosts require lifecycle and risk review. • Cloud-hosted and externally exposed services require clearer ownership and validation. • Asset, exposure and remediation evidence is not yet consolidated into a single register.
Zero-Cost Quick Wins	• Create a consolidated asset register for endpoints, servers, ESXi hosts, cloud services and externally exposed systems. • Record system owners, support status, business criticality and remediation owner.

	• Document ESXi 7 hosts and the associated risk acceptance or upgrade plan. • Link asset records to Cyber Essentials Plus and ISO 27001 evidence.
Recommended Solutions	• Introduce dedicated vulnerability scanning across endpoints, servers, ESXi hosts and internet-facing services. • Include DigitalOcean and Google Cloud Storage configuration in assurance review. • Maintain a remediation register with owners, target dates, exception rationale and closure evidence. • Use asset criticality to prioritise vulnerability remediation and recovery planning.
Strategic Remediation Rationale	A shared asset and exposure register would connect operational inventory with vulnerability findings, system ownership and remediation decisions. The same record would support incident response, recovery planning and ISO 27001 preparation without assuming that existing assets are unmanaged.
Partnership Recommendations	Planet IT can support asset and exposure register design, vulnerability-scanning scope, legacy virtualisation risk review, cloud assurance and remediation planning. Acme Corp would retain ownership of asset classification, risk acceptance and operational remediation.

Domain: Monitoring & Detection

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp's IT team reviews user reports and available endpoint-security alerts through its service-management platform during normal working hours, sharing issues within the team as needed. Investigation currently draws on separate endpoint, firewall, cloud productivity and email records. That approach gives the team day-to-day visibility, but it does not provide a dedicated analyst-led service to triage and correlate suspicious activity at all hours.
Business Impact & Risk	During a material incident, the internal team may need to correlate Webroot, Google Workspace, Fortinet, Freshdesk, email and file-access evidence manually and under pressure. This could delay scoping, containment and executive communication, particularly outside normal working hours.
Critical Gaps	• No dedicated MDR or 24/7 SOC capability is currently in place. • Alerting is distributed across existing operational tools. • Cross-domain telemetry correlation is not yet mature. • Out-of-hours escalation and containment authority should be clarified.

Zero-Cost Quick Wins	• Confirm which alerts and logs are available from Webroot, Fortinet, Google Workspace, Freshdesk and any email-security tooling. • Define out-of-hours escalation routes for suspected compromise. • Record what the internal team can contain directly and what requires supplier involvement. • Build an incident evidence checklist for phishing, account compromise, data access and ransomware scenarios.
Recommended Solutions	• Evaluate MDR options against Acme Corp's lean-team operating model, insurance expectations and need for cross-domain investigation. • Validate telemetry readiness before selecting a service. • Consider whether MDR-integrated email and endpoint monitoring would reduce investigation pressure. • Use incident-response testing and downtime-cost modelling to decide which monitoring improvements justify investment.
Strategic Remediation Rationale	Internal monitoring provides a useful baseline during working hours. The limiting factors are out-of-hours capacity, alert coverage and the effort needed to connect activity across tools. MDR should be assessed against those specific needs: timely triage, agreed containment support and a clearer account of what happened.
Partnership Recommendations	Planet IT can assess MDR options, available logs and alert handling, then agree escalation and containment thresholds with Acme Corp. Acme Corp approves business-impacting response actions and retains operational change control.

Domain: Supplier Assurance

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with key supplier dependencies understood but not yet fully formalised into an assurance model.
Technical Analysis	Acme Corp relies on several important suppliers and platforms, including managed network and firewall services, cloud productivity and hosting platforms, endpoint and device-management tooling, external file-sharing, HR SaaS and Planet IT for incident support. The consultation indicates that supplier relationships are operationally understood, but incident-notification expectations, access routes, recovery dependencies and assurance evidence should be more clearly documented.
Business Impact & Risk	If supplier responsibilities, access routes or incident-notification expectations are unclear, Acme Corp may lose time during a security incident or outage. This could affect firewall management, cloud-hosted services, email and productivity platforms, HR SaaS, file-transfer routes or production support activities.
Critical Gaps	• Critical supplier dependencies require clearer documentation.

	• Supplier incident-notification routes and escalation expectations should be formalised. • Supplier access paths and administrative responsibilities require periodic review. • Recovery dependencies should be linked to the incident-response and disaster-recovery plan.
Zero-Cost Quick Wins	• Create a supplier assurance register covering owner, service, data type, access method, incident contact and recovery dependency. • Confirm Spire escalation routes for MPLS and Fortinet firewall issues. • Record support and escalation routes for Google Workspace, DigitalOcean, Webroot, Kanji/Iru, WeTransfer and Breathe HR. • Include supplier escalation contacts in incident-response documentation.
Recommended Solutions	• Establish a lightweight supplier assurance process aligned to ISO 27001 planning. • Review supplier access and administrative privileges periodically. • Confirm incident-notification and response expectations with critical suppliers. • Include supplier failure, firewall escalation and cloud-service disruption scenarios in tabletop exercises.
Strategic Remediation Rationale	A supplier register can give Acme Corp a usable incident contact and dependency map. For each critical service, record the owner, support route, administrative access, notification expectations and recovery dependency; then test those contacts during the tabletop exercise.
Partnership Recommendations	Planet IT can support supplier dependency mapping, incident escalation design, supplier assurance templates and tabletop testing. Acme Corp would retain ownership of supplier relationships, contractual decisions and operational acceptance of third-party risk.

Domain: Third-Party Access

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with known access paths but incomplete assurance over all third-party and external routes.
Technical Analysis	Acme Corp's third-party and external access model includes VPN access for remote users, customer access through the client-facing portal, internal file-transfer access, supplier-managed network and firewall infrastructure, and externally exposed services associated with web hosting and file exchange. MFA is broadly used across supported services, but the file-transfer service remains a material exception. The key requirement is to document who has access,

	how access is authenticated, what data or systems are reachable, and how access is reviewed or removed.
Business Impact & Risk	Unclear third-party or external access controls could expose customer files, production workflows, supplier-managed infrastructure or externally facing systems. The business impact would be greatest where access affects the client-facing portal, internal file-transfer service, file servers, cloud-hosted services, the cloud productivity suite or firewall-management dependencies.
Critical Gaps	• FTP access remains a significant MFA and external-sharing exception. • Third-party and supplier access routes require clearer documentation and periodic review. • Customer access through the client-facing portal should be included in access and application-security assurance. • Externally exposed services and VPN use should be linked to the asset and supplier assurance registers.
Zero-Cost Quick Wins	• Document third-party access routes, owners, users, authentication methods and data access. • Review FTP users, restrictions, locations and termination process. • Confirm client-facing portal customer access controls and ownership. • Include supplier and administrator access review in the security improvement register.
Recommended Solutions	• Address FTP MFA or replace FTP with a more controlled transfer model. • Review supplier and administrator access paths and termination controls. • Include third-party access paths in vulnerability scanning and tabletop scenarios. • Establish a recurring access review cadence for external, supplier and customer-facing systems.
Strategic Remediation Rationale	A regular review of external and supplier access would give Acme Corp a reliable record of who can reach customer files and production systems, how that access is authenticated and when it ends. The record would also speed up audit and incident escalation.
Partnership Recommendations	Planet IT can support access-route discovery, file-transfer remediation planning, supplier-access review and tabletop scenario design. Acme Corp would retain ownership of access approval, customer-facing process decisions and supplier relationship management.

Domain: Recovery Assurance

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with established backup foundations for on-premises workloads.
Technical Analysis	Acme Corp has a meaningful backup foundation for on-premises workloads and file servers, including backup software, local storage and off-site copies. The recovery-assurance gap is therefore not that backups are absent, but that recovery expectations, cloud-productivity backup requirements, restore testing evidence and incident-led recovery sequencing need clearer validation.
Business Impact & Risk	If a material incident affected file servers, the cloud productivity suite, core business-management systems, the automation platform or the client-facing portal, the organisation would need to understand what can be restored, how quickly, from which location and in what order. Without this validation, recovery may take longer than expected even where backup technology exists.
Critical Gaps	• Google Workspace data is not independently backed up to another cloud platform. • Recovery priorities for critical systems have not yet been fully validated. • Restore testing evidence and recovery sequencing should be strengthened. • System-level RTO and RPO targets need to be defined.
Zero-Cost Quick Wins	• Document recovery expectations for core business-management systems, the automation platform, client-facing portal, file servers and cloud productivity services. • Confirm existing Veeam and QNAP restore testing evidence. • Identify the most important restore scenarios and data sets. • Record which systems would be recovered first during a site, ransomware or cloud-data incident.
Recommended Solutions	• Review Google Workspace backup requirements against retention, versioning, recovery testing and cost. • Perform representative restore tests for critical file and workload scenarios. • Include recovery sequencing in a disaster-recovery tabletop exercise. • Consider immutable or isolated storage where it supports the agreed recovery model.
Strategic Remediation Rationale	Existing local and off-site copies already protect on-premises workloads. The next task is to test representative restores, agree system recovery order and determine whether the cloud productivity suite's native recovery options meet Acme Corp's needs.
Partnership Recommendations	Planet IT can support recovery requirement definition, cloud-productivity backup review, restore-test planning and disaster-recovery tabletop exercises. Acme Corp would retain ownership of data prioritisation, recovery targets and operational scheduling.

Domain: Incident Response

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp's incident-response documentation is in progress; consultation did not establish that it has been exercised with directors. Planet IT would be contacted for additional support, and no separate paid incident-response retainer is currently in place. A tabletop involving IT, directors and business decision-makers would test escalation, authority and recovery decisions.
Business Impact & Risk	If an incident occurred before the response model is tested, Acme Corp may lose time deciding who owns containment, customer communication, insurer notification, supplier escalation, regulatory assessment and recovery sequencing. This is particularly important given the organisation's low tolerance for downtime and reliance on customer-facing production systems.
Critical Gaps	• Incident-response documentation has not yet been validated through a practical exercise. • Director-level responsibilities and business decision points need clarification. • Insurer, supplier, PR and regulatory notification routes should be documented. • Response actions should be linked to recovery priorities and available telemetry.
Zero-Cost Quick Wins	• Review the current incident-response documentation. • Define roles for IT, leadership, communications, insurer engagement and supplier coordination. • Create contact lists and escalation paths. • Run a short internal walkthrough before a full tabletop exercise.
Recommended Solutions	• Run a board-level tabletop exercise based on a realistic ransomware, data-access or operational outage scenario. • Develop practical playbooks for phishing-led account compromise, ransomware, FTP compromise, customer-data exposure and site outage. • Align incident-response plans with cyber-insurance requirements and downtime-cost modelling. • Confirm whether MDR would provide useful 24/7 investigation support.
Strategic Remediation Rationale	An exercised response plan would give IT and directors agreed contacts, decision rights and recovery order before an incident occurs. A tabletop is the practical test of whether the documentation supports those decisions under pressure.
Partnership Recommendations	Planet IT can support incident-response review, tabletop design, MDR readiness and post-exercise improvement planning. Acme Corp would retain ownership of decision authority, customer communications and internal adoption.

Domain: Network & Edge

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with established perimeter management.
Technical Analysis	The network and edge posture spans multiple UK locations connected through a managed wide-area network and protected by centrally managed firewall infrastructure. A third-party provider manages the network and firewall environment from a hosted data-centre platform. The main network assurance areas are validation of geographic access controls, visibility of externally exposed services, file-transfer security, internal segmentation and the impact of legacy virtualisation hosts retained for licensing reasons.
Business Impact & Risk	Network or edge weaknesses could increase the impact of an account compromise, FTP exposure or server vulnerability. If an attacker reached internal infrastructure, the business impact could include disruption to file servers, production systems, site operations or backup-related systems.
Critical Gaps	• Geo-locking requires configuration or validation. • FTP access requires stronger control. • ESXi 7 exposure and support position should be risk-reviewed. • Internal segmentation and externally exposed services need assurance.
Zero-Cost Quick Wins	• Confirm Fortinet geo-locking and firewall policy posture with Spire. • Review FTP exposure and restrict access where possible. • Document ESXi 7 hosts, workload criticality and risk acceptance. • Confirm public-facing services and ownership.
Recommended Solutions	• Introduce targeted vulnerability scanning for network infrastructure, ESXi hosts and internet-facing services. • Review segmentation and administrative access paths. • Confirm Fortinet logging and whether it can support MDR investigation. • Include FTP and remote-access routes in security testing scope.
Strategic Remediation Rationale	A third-party provider already manages Acme Corp's perimeter. The next review should concentrate on file-transfer exposure, geographic access controls, legacy virtualisation support and public-facing services, with scanning and logging used to establish which changes are needed. A firewall replacement is not indicated by the consultation.
Partnership Recommendations	Planet IT can support network assurance review, supplier coordination, vulnerability-scanning scope, firewall logging review and MDR telemetry planning. Acme Corp would retain ownership of network-change approval and business risk acceptance.

Domain: Email Security

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Email security is currently provided through Google Workspace native protections rather than a separate gateway such as Mimecast or Barracuda. Google spam-trend alerts and user reports are reviewed by the IT team, who search email history and logs to determine who received a suspicious message and whether any activity occurred. This provides a workable baseline, but phishing protection, recurring phishing simulation, reporting evidence and MDR-integrated email visibility should be reviewed as part of future maturity planning.
Business Impact & Risk	Email remains a credible initial access route because it is closely tied to customer communication, file sharing and production workflows. A successful phishing-led compromise could expose customer files, shared links, mailbox content or access to connected SaaS services.
Critical Gaps	• No separate email-security gateway is currently deployed. • Formal phishing training or simulation has not been run recently. • Email investigation depends on internal review during normal working hours. • Email telemetry is not currently part of a managed 24/7 investigation model.
Zero-Cost Quick Wins	• Review Google Workspace email security configuration and alerting. • Re-establish user phishing-awareness activity. • Document the process for searching message history and identifying affected recipients. • Review SPF, DKIM and DMARC posture.
Recommended Solutions	• Compare Google-native controls with email-security options such as Mimecast, Barracuda or Sophos Email if additional protection or reporting is required. • Consider MDR-integrated email visibility where it improves incident scoping. • Run recurring phishing simulations and targeted coaching. • Feed phishing outcomes into the security improvement register.
Strategic Remediation Rationale	The cloud productivity suite provides Acme Corp's existing email protection. Review recent suspicious-message reports, configuration and investigation records first; then compare additional filtering or managed email monitoring against any gaps that remain. This gives Acme Corp a clear basis for deciding whether an extra service would improve protection or response.
Partnership Recommendations	Planet IT can support cloud-email security review, phishing-awareness design, email-security comparison and MDR email-monitoring evaluation. Acme Corp would retain ownership of user communications and final vendor selection.

Domain: Endpoint Security

Field	Details
Current Maturity	Pillar 2: Proactive Cybersecurity
Technical Analysis	Endpoint security is delivered through an endpoint detection and response platform across end-user devices, with device-management tooling used for application deployment, operating-system patching and application patching. The estate is predominantly macOS, supported by a smaller Windows environment. The main endpoint risks are staged macOS patching that can miss the intended patching target, uncertain alerting visibility, lack of dedicated vulnerability scanning, and the need to formalise administrator-password renewal for local IT-managed accounts.
Business Impact & Risk	A compromised endpoint could provide access to customer files, Google Workspace, shared drives, production workflows or administrative tooling. The impact would depend on the user, device privileges and whether activity is detected quickly.
Critical Gaps	• macOS patching is staged and can miss the intended 14-day target. • Webroot alert volume is low, creating uncertainty over visibility. • Dedicated vulnerability scanning is not currently in place. • Administrator-password renewal needs to be formalised.
Zero-Cost Quick Wins	• Review Webroot alerting, coverage and reporting. • Validate Kanji/Iru patch status across Mac and Windows devices. • Document macOS patching exceptions and staged rollout rationale. • Implement or schedule local administrator-password renewal.
Recommended Solutions	• Evaluate a dedicated vulnerability-scanning capability. • Confirm whether endpoint telemetry can support MDR investigation. • Review application-control capability for unauthorised tools and shadow AI. • Include Mac-specific threat assumptions in awareness and incident-response planning.
Strategic Remediation Rationale	The existing endpoint-security and device-management platforms give Acme Corp a useful baseline. Coverage checks, dedicated vulnerability discovery and patch reporting that reflects staged macOS rollouts would make that baseline easier to verify and maintain.
Partnership Recommendations	Planet IT can support endpoint coverage review, endpoint and device-management assurance, vulnerability-scanning design and MDR telemetry planning. Acme Corp would retain ownership of rollout timing and user-impact decisions.

Domain: Cloud Security

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity
Technical Analysis	Acme Corp primarily uses a cloud productivity suite and internally hosted systems, while web workloads are being moved to a public-cloud hosting provider and cloud object storage supports a database workload. A secondary productivity platform is used only to a limited extent for desktop applications and selected authentication needs. The main cloud-security considerations are productivity-suite recovery assurance, SaaS access governance, hosting controls, cloud-storage oversight and visibility of external data-sharing routes.
Business Impact & Risk	Cloud and SaaS services support communication, file storage, customer collaboration and business operations. If access, configuration or data recovery controls are not well understood, an incident could affect customer data, production workflows or recovery confidence.
Critical Gaps	• Google Workspace data is not independently backed up to another cloud platform. • DigitalOcean hosting controls should be reviewed as migration progresses. • Google Cloud Storage oversight should be documented. • SaaS application ownership, SSO and MFA status should be kept current.
Zero-Cost Quick Wins	• Document key cloud and SaaS services, owners and authentication method. • Review Google Workspace retention and version-history limitations. • Confirm DigitalOcean administrative access and MFA. • Record Google Cloud Storage purpose, ownership and access model.
Recommended Solutions	• Review Google Workspace backup options if native recovery is insufficient. • Include DigitalOcean and Google Cloud Storage in vulnerability and configuration review. • Maintain a SaaS register covering SSO, MFA, owner and data sensitivity. • Integrate cloud and SaaS events into MDR telemetry where practical.
Strategic Remediation Rationale	Acme Corp's principal cloud dependencies are its cloud productivity suite, public-cloud hosting, cloud object storage and SaaS applications that support production. Assurance should follow those services: confirm owners and access, review hosting configurations, and test whether current recovery options meet agreed business needs. Limited use of a secondary productivity platform does not warrant a platform-led cloud plan.

Partnership Recommendations	Planet IT can support cloud-productivity recovery review, hosting and cloud-storage assurance, SaaS governance and MDR telemetry planning. Acme Corp would retain ownership of platform administration and business-risk decisions.

Domain: Application Security

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with key applications known but application-security assurance requiring validation.
Technical Analysis	Acme Corp's critical application dependencies include its core business-management system, automation platform, client-facing portal, internally hosted web services and web workloads being moved to a public-cloud hosting provider. The consultation did not establish a mature application-security testing programme or secure-development assurance model, so firm conclusions about code-level risk should not be drawn without further validation. The most proportionate next step is to confirm ownership, external exposure, authentication model, hosting location, data sensitivity and testing history for priority applications.
Business Impact & Risk	A weakness in the client-facing portal, core business-management systems, automation workflows or externally hosted web services could affect customer file access, production scheduling, job delivery or customer confidence. The impact would depend on the application affected, the data exposed and whether the issue caused service disruption, data alteration or unauthorised access.
Critical Gaps	• Application ownership, exposure and data sensitivity should be documented for priority systems. • The client-facing portal and externally facing web workloads require targeted assurance. • DigitalOcean migration should include configuration and access review. • Application testing history and remediation ownership are not yet consolidated.
Zero-Cost Quick Wins	• Build a priority application register covering owner, hosting location, authentication, data type and business criticality. • Confirm which applications are externally exposed and who approves changes. • Review client-facing portal access and customer-facing workflow controls. • Link application assurance actions to the security improvement register.
Recommended Solutions	• Conduct targeted application testing for the client-facing portal and priority externally facing workloads. • Include DigitalOcean-hosted services in vulnerability and configuration review. • Define application change, access and remediation ownership for critical systems.

	• Include application compromise scenarios in incident-response and recovery exercises.
Strategic Remediation Rationale	The client-facing portal and other production-critical applications need a documented owner, exposure profile and testing history. Targeted testing of customer-facing and externally hosted services can then establish which issues require remediation. The consultation alone does not support a conclusion about code-level weaknesses.
Partnership Recommendations	Planet IT can support application inventory, testing scope, cloud-hosting assurance, remediation planning and incident-scenario design. Acme Corp would retain ownership of application design decisions, development priorities and customer workflow changes.

Domain: AI Governance

Field	Details
Current Maturity	Pillar 1: Reactive Cybersecurity, with existing governance foundations.
Technical Analysis	Acme Corp has an AI usage policy that requires proposed new AI tools to be submitted to management. The organisation aims to use centrally managed business accounts rather than personal accounts. Several approved generative-AI services are in use to differing degrees. The main remaining risk is personal or unapproved AI usage where company or customer information could be uploaded outside approved business accounts.
Business Impact & Risk	Acme Corp has an AI usage policy and centrally managed business accounts for approved tools. The remaining exposure is information entered into personal or unapproved services, where monitoring and enforcement are less clear. Customer files, production information and commercially sensitive material should be covered by explicit handling rules.
Critical Gaps	• Shadow-IT policy is still being developed. • Technical controls for blocking or monitoring unapproved AI tools are not yet mature. • Webroot application-control capability has not yet been fully tested. • DLP controls are not currently deployed to govern outbound data movement.
Zero-Cost Quick Wins	• Complete the shadow-IT policy. • Define approved AI tools, account ownership and prohibited data types. • Communicate that personal AI accounts must not be used for company or customer data. • Test Webroot application-control capability where appropriate.

Recommended Solutions	• Review firewall, web-control and endpoint options for identifying unapproved AI usage. • Consider future AI monitoring capabilities where they provide measurable value. • Align AI guidance with data classification and external sharing policy. • Include AI misuse scenarios in awareness activity.
Strategic Remediation Rationale	The existing policy and business-account approach give Acme Corp a starting point for AI governance. Completing the shadow-IT policy, defining prohibited data and checking what browser, endpoint or network controls can show would clarify where technical enforcement is useful.
Partnership Recommendations	Planet IT can support AI policy review, shadow-IT control assessment, application-control testing and future AI monitoring evaluation. Acme Corp would retain ownership of acceptable-use decisions and staff communication.

Security Testing and Planning

Proactive Security Testing

Start by reviewing the scope, findings and remediation evidence from Acme Corp's annual penetration testing. Add dedicated vulnerability scanning across endpoints, servers, virtualisation hosts, file servers, internet-facing services and representative network infrastructure to identify issues between formal tests. Scanning complements Cyber Essentials Plus and penetration testing; it does not replace either.

Testing should be shaped around Acme Corp's most credible risk paths: phishing-led identity compromise, unauthorised access to customer files, file-transfer exposure, staged macOS patching, legacy virtualisation hosts, externally exposed services, and the ability to detect and contain suspicious activity using endpoint, firewall, cloud-productivity and service-management evidence. Findings should be prioritised by exploitability, business criticality and operational impact rather than relying on severity scores alone.

Where appropriate, test objectives should be mapped to realistic attacker behaviours such as Spearphishing Link (T1566.002), Valid Accounts (T1078), Account Discovery (T1087), Email Collection (T1114), Data from Cloud Storage (T1530), Remote Services (T1021) and Exfiltration Over Web Service (T1567). This will make findings easier to connect to Acme Corp's real operating model and will help distinguish immediate remediation items from longer-term maturity improvements.

Incident Response Planning

Incident response planning should focus on validating the documentation already in progress and turning it into a practical operating model. The consultation did not establish that the incident-response plan has been fully incorporated, tested or rehearsed with directors. The priority is therefore to define who owns containment, customer communication, insurer notification, supplier escalation, regulatory assessment and recovery sequencing before a live incident occurs.

Initial playbooks should focus on the scenarios most relevant to Acme Corp's current environment: phishing-led cloud-account compromise, file-transfer compromise, unauthorised customer-file access, ransomware affecting file servers, disruption to core business-management systems or the automation platform, client-facing portal outage, and compromise of a privileged IT account or administrator workstation.
A facilitated tabletop exercise should include IT, directors and business decision-makers, rather than being limited to the technical team. The exercise should test decision ownership, communications, insurer engagement, supplier coordination, evidence preservation, customer assurance and recovery

prioritisation. MDR should be assessed in this context: its value would be greatest where it reduces pressure on the lean internal team and provides analyst-led triage outside normal working hours.

Disaster Recovery Planning

Disaster recovery planning should begin by defining system-level recovery expectations rather than assuming a single recovery target across the estate. Acme Corp's critical dependencies include core business-management systems, the automation platform, client-facing portal, file servers, cloud productivity services, site infrastructure and supporting network connectivity. Each dependency should have an agreed recovery priority, owner, recovery method and acceptable data-loss position.

Acme Corp already has a meaningful backup foundation for on-premises workloads and file servers, including local backups, off-site copies and cloud synchronisation for selected file-server data. The gap is therefore not an absence of backups, but the need to validate restore evidence, recovery sequencing, cloud-productivity recovery requirements and operational decision-making during an incident.

A practical next step would be to document recovery dependencies, perform representative restore tests, review Google Workspace backup options where native controls and version history are insufficient, and run a scenario-based disaster recovery exercise. The exercise should cover customer-file access, site disruption, Google Workspace data integrity, supplier escalation and customer communication so that technical recovery can be aligned with business priorities.

Suggested Implementation Roadmap

Six workstreams shape this roadmap: MDR readiness, incident-response rehearsal, vulnerability scanning, file-transfer remediation, cloud-productivity recovery assurance, and data classification with AI governance. Timing is indicative and should be confirmed against Acme Corp's capacity, dependencies and funding decisions.

Phase 1 establishes decisions and evidence: confirm MDR telemetry and escalation requirements, choose an approach to FTP, assign incident-response roles and define recovery needs. Phase 2 implements or validates monitoring and scanning, then rehearses the response with directors. Phase 3 keeps supplier, data, AI and recovery controls under regular review.

- **Phase 1: Control assurance and immediate risk reduction:** Addresses the highest-confidence gaps affecting resilience and client-data exposure, including MDR readiness, FTP MFA, privileged-account hygiene, incident-response ownership and Google Workspace recovery requirements.
- **Phase 2: Monitoring, vulnerability management and response validation:** Moves Acme Corp from internal reactive review towards validated detection, response and vulnerability visibility through MDR onboarding, telemetry validation, dedicated vulnerability scanning and executive tabletop testing.
- **Phase 3: Governance, resilience and AI control maturity:** Embeds repeatable governance, ISO 27001-aligned evidence, supplier assurance, data classification, AI and shadow-IT controls, and recurring recovery validation.

The phases separate decisions that can be made now from changes that need supplier input, testing or funding. Each phase should close with named owners, recorded evidence and an agreed next decision.

Phase & Timeline	Objective	Capability focus
Phase 1: Control Assurance and Immediate Risk Reduction (0–3 Months)	Close the most urgent resilience and control gaps before larger investments are committed.	Confirm MDR telemetry and response requirements, decide how to secure or replace FTP, establish administrator-password renewal and incident ownership, and define Google Workspace recovery

		needs. Record decisions and owners in the improvement register.
Phase 2: Monitoring, Vulnerability Management and Response Validation (3–9 Months)	Move from internal reactive review towards validated detection, response and vulnerability visibility.	Onboard MDR if approved; start dedicated vulnerability scanning and remediation tracking; run an executive tabletop; and review phishing awareness and Google Workspace email controls. Use the exercise and downtime-cost model to test the investment case.
Phase 3: Governance, Resilience and AI Control Maturity (10–18+ Months)	Embed repeatable governance, recovery assurance and data-control maturity.	Maintain ISO 27001 planning evidence, asset and supplier records, customer-data classifications, AI and shadow-IT rules, recovery tests and periodic reporting to leadership. Assign an owner and review date to each continuing control.

The tables below set out deliverables, decision points and the people needed for each phase. MDR readiness remains urgent because Acme Corp needs a clear route for investigating and containing incidents outside normal working hours.

Partnership & Success Criteria

Planet IT can provide specialist support while Acme Corp continues to run day-to-day IT operations and make business-risk decisions. The proposed support covers security architecture, control validation, vulnerability-management planning, MDR evaluation, tabletop facilitation, cloud-productivity recovery review and the executive business case.

Success is measured by decisions and evidence: confirmed MDR telemetry readiness; a decision on file-transfer remediation or replacement; named incident-response owners; an agreed vulnerability-scanning scope; cloud-productivity recovery requirements; and an improvement register that supports ISO 27001 planning.

If Acme Corp selects MDR, review onboarding, the signals available to analysts, escalation and containment thresholds, and the quality of incident investigations. Acme Corp remains responsible for operational changes and customer communications, with Planet IT providing specialist advice and support where agreed.

Field	Details
Phase	Phase 1: Control Assurance and Immediate Risk Reduction
Timeline	0–3 Months
Strategic Objective	Close the highest-confidence control gaps that affect resilience, client-data exposure and leadership decision-making before larger investments are committed.
Key Deliverables	• MDR readiness discovery, including telemetry review across Webroot, Fortinet, Google Workspace, Freshdesk, email and cloud services. • FTP MFA or secure-transfer decision paper covering access restrictions and replacement options. • Local administrator password-renewal process for IT-managed accounts.

	• Incident-response ownership matrix covering IT, directors, insurers, suppliers and customer communications. • Google Workspace recovery requirements for priority mail, Drive and shared-data scenarios. • Initial security improvement register covering owners, target dates, evidence and accepted risks.
Estimated Effort	Moderate effort / high immediate value
Key Milestones	• Confirm MDR telemetry availability and onboarding dependencies. • Decide whether FTP will be remediated in place or replaced. • Establish a privileged-account renewal cadence. • Confirm incident-response roles and escalation contacts. • Agree initial recovery expectations for Google Workspace and critical production systems. • Launch the security improvement register for tracking through later phases.
Expected outcome	Reduces immediate uncertainty around MDR, FTP exposure, privileged access, incident ownership and recovery expectations. Provides the evidence base needed for budget approval and prioritised delivery.
Resource Requirements	Client IT, Planet IT security architecture, managed network-provider input for firewall and logging where required, cloud-productivity administration, endpoint and device-management administration, the business owner for file transfer and a director-level incident-response sponsor.
Field	**Details**
Phase	Phase 2: Monitoring, Vulnerability Management and Response Validation
Timeline	3–9 Months
Strategic Objective	Move from internal reactive review towards validated detection, response and vulnerability visibility across the most important attack paths.
Key Deliverables	• MDR onboarding or a final MDR business case, including agreed response authority and escalation model. • Dedicated vulnerability scanning across Macs, Windows devices, ESXi hosts, file servers, internet-facing services and priority infrastructure. • Remediation register for scan findings, with owners, target dates and closure evidence. • Executive tabletop exercise covering ransomware, customer-file exposure or operational outage. • Restarted phishing-awareness and simulation programme with targeted user coaching. • Email-security and Google Workspace alerting review, including whether additional protection is justified.

Estimated Effort	Moderate to high effort / reduced exposure through testing and response coverage
Key Milestones	• Complete MDR telemetry validation and the service-selection decision. • Begin vulnerability scanning and remediation reporting. • Hold the executive tabletop and record lessons learned. • Confirm response playbooks for phishing, FTP compromise, ransomware and customer-file exposure. • Review Google Workspace and email-security configuration. • Use downtime-cost modelling to support investment decisions.
Expected outcome	Improves out-of-hours detection and response capability, reduces unknown technical exposure, validates business decision-making and provides measurable evidence of progress against the highest-priority risks.
Resource Requirements	Client IT, Planet IT security architecture, the MDR provider if selected, endpoint and firewall administrators, cloud-productivity administration, the executive sponsor, relevant suppliers and business owners for critical systems.
Field	**Details**
Phase	Phase 3: Governance, Resilience and AI Control Maturity
Timeline	10–18+ Months
Strategic Objective	Embed repeatable governance, recovery assurance and data-control maturity once monitoring, vulnerability management and response validation are established.
Key Deliverables	• ISO 27001-aligned security improvement and risk register maintained as a governance record. • Data classification model for customer files, production data and commercially sensitive information. • Completed shadow-IT and AI governance controls covering approved tools, prohibited data types and personal AI account restrictions. • Supplier assurance register covering Spire, Google Workspace, DigitalOcean, Google Cloud Storage, Webroot, Kanji/Iru, WeTransfer, Breathe HR and Planet IT incident-support dependencies. • Recovery testing cadence for Veeam, QNAP, critical file-server data and Google Workspace recovery scenarios. • Periodic leadership reporting against risk reduction, control evidence and outstanding exceptions.
Estimated Effort	Moderate ongoing effort / governance maturity
Key Milestones	• Agree ownership of the security improvement register and its update cadence. • Complete customer-data classification and the external-sharing review.

	• Confirm the AI and shadow-IT policy position and communication plan. • Document key supplier dependencies, access routes and escalation expectations. • Complete representative recovery tests and record evidence. • Produce periodic security progress reporting for leadership.
Expected outcome	Converts the assessment into a sustainable security governance model, improves audit and ISO 27001 readiness, strengthens supplier and data governance, and gives leadership evidence of continuing risk reduction.
Resource Requirements	Client IT, data owners, application owners, senior leadership, Planet IT advisory support, supplier contacts, cloud-productivity administration and relevant security or compliance stakeholders.

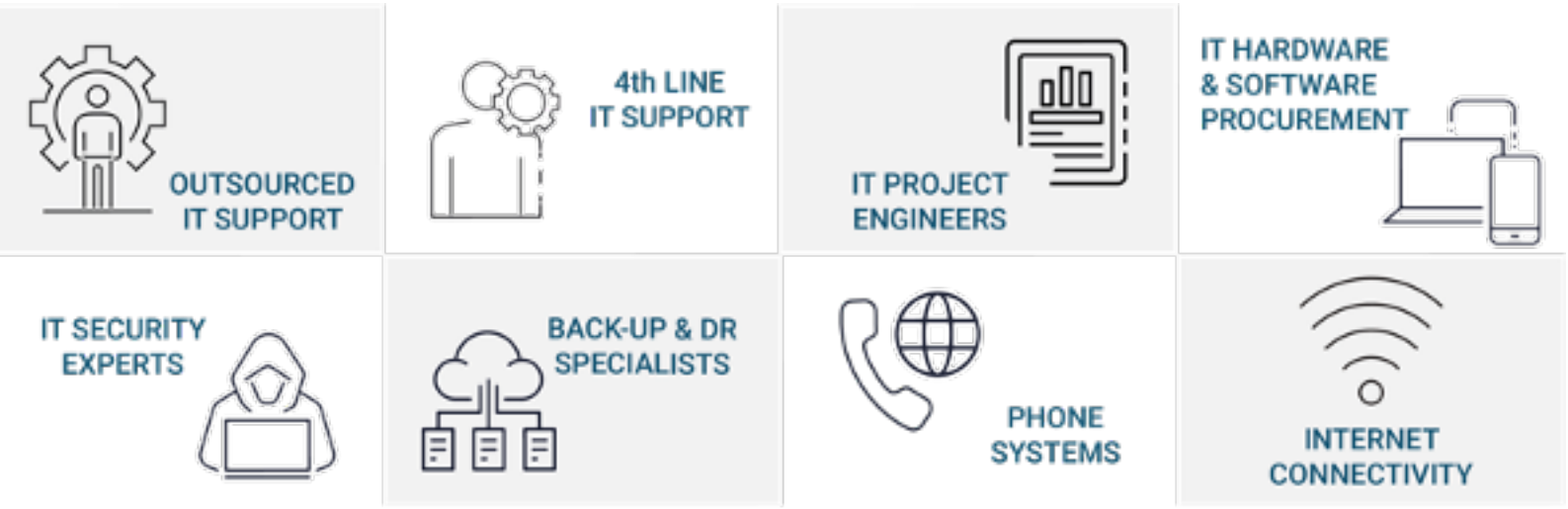
Why Planet IT

Planet IT is a leading IT company offering complete outsourced IT solutions to organisations across the UK and Europe. Based in Milton Park, Oxford, we provide comprehensive support services to suit your needs and deliver business transformation.

PLANET IT part of TalkTalk Business

Our expert team has an extensive record of delivering software and hardware solutions to major blue-chip clients. Our technicians are highly skilled in planning, implementing and troubleshooting.

At Planet IT, we always take time to assess your IT needs and existing infrastructure, make recommendations, and implement improvements quickly and efficiently. In addition, we are highly experienced in planning and installing entire new IT systems in large organisations.











































Our Pedigree

Since we started in 2003, Planet IT has supported over 2,000 clients in the UK, US and Europe. We are trusted by businesses across multiple industries, delivering various projects across Security, Backup

PLANET IT part of TalkTalk Business

Disaster Recovery, Cloud migration, Fully Managed Support, Device as a Service and software licencing.

Since the beginning, we have built our business on first-class customer service and employing the best people available. We continue that ethos today, constantly building and maintaining our client relationships. Here's a snapshot of some of the customers we work with today.

Yeo Valley Family Farm

VOGUE

IWM Imperial War Museums

Quakers

GQ

Oxford PharmaGenesis The HealthScience Communicators

Premier League

Harlow College

Royal College of Music London

Royal Opera House

ResMed

Condé Nast

National Portrait Gallery

ESPN

University of Oxford

Lord's The Home of Cricket

Oxford City Council

Oxford Space Systems

Mountain Warehouse

BBC

Museum of London

Barbour

SAS International

Gigaclear

HSL Compliance

nova Education Trust

www.Planet-IT.net

Assumptions and Client Responsibilities

This agreement is between;

A. Acme Corp ("The Client")
B. Planet IT ("The Provider")

Project Assumptions

This Statement of Work is offered by Planet IT based on the assumptions outlined below:

- The project will be delivered using the resources outlined within the document. Any delays to the project caused by The Client will result in additional days required to complete the project, these additional days will be at cost to The Client.
- Should the scale of the project transpire to be greater than initially expected, The Client are responsible for any additional time required to complete the project.
- The project will be delivered without interruption or suspension by The Client.
- Tasks assigned to The Client resources as part of detailed resource planning will be completed on time.
- Information and documentation requested by Planet IT for this project will be accurate, complete and provided in soft copy within two days.
- Reasonable requests from Planet IT to The Client for functional or technical clarification will be responded to within one business day. Failure to respond during the allocated time frame could have an impact on timelines and associated cost.
- The Client accepts that Planet IT's professional services team members will perform their duties through a combination of on-site and off-site activity.
- The Client accepts non-exclusive access to the Planet IT's professional services team members during the project.
- Planet IT documentation deliverables will be provided in editable formats such as Microsoft Word or Excel as applicable.
- Where applicable installation and/or configuration of The Client owned application software will be the responsibility of The Client.
- Any representatives of The Client (or their associates) that are involved at the various steps in the project are available as planned, adequately skilled and competent to execute the tasks required of them.
- Any The Client nominated decision-making representative is duly empowered.
- Planet IT will receive a minimum of five working days' notice of any rescheduling of work resulting from delays caused by The Client, or their contractors.
- The Client will provide single point of contact for all aspects relating to project delivery.
- Network connectivity IP addresses and naming conventions will be provided by The Client where applicable.
- Business hours are standard UK business hours, 7.5 hour working day.
- The project will operate as a gated system. The project will be placed on hold and resources suspended until gate controls are met.
- The Client will be responsible for undertaking any appropriate user acceptance testing and sign off as accepted based on the outlined test schedule.
- If The Client opts out of user acceptance testing, Planet IT will not assume accountability for any project failures. It is the responsibility of The Client to address any necessary remediation work.

Client Responsibilities

These following items are responsibilities that The Client needs to fulfil as part of the project:

- Documentation/deliverables provided as part of the project will go through a maximum of two The Client reviews unless mutually agreed.
- In order to avoid delays to the project, The Client must review the documentation/deliverables within two business days of receipt of the document, except where mutually agreed.
- The Client is responsible for the supply of all infrastructure (hardware, software licences, network and environments) requirements to successfully deliver the project.
- The Client will be responsible for all aspects of data quality, availability, backups and restores required to successfully deliver the project.
- The Client will be responsible for raising all necessary change control requests.
- The Client will provide site access and a suitable work area to the project team.
- The Client will provide internal staff as per the schedule or as reasonably required including, but not limited to:
    - Project Manager to liaise with Planet IT Technical Design Authority to assist with scheduling The Client deliverables, resources and activity as per the agreed schedule.
    - Availability of appropriate The Client representatives at necessary requirements, design and planning workshops, testing and validation activities.
    - Provide access to network information, diagrams, site floor plans or site assistance, indicating outlet location, station number, username, and station type for each site where applicable.
    - Third party vendor coordination excluded from the scope of this proposal unless directly included in scope.
    - Supplying third party resources to assist in interfacing with third party equipment.
    - The successful execution and completion of User Acceptance Testing.
- The Client will inform Planet IT of any health and safety requirements.
- Ensure that Planet IT personnel who attend The Client site are instructed on all relevant health and safety regulations and criteria.
- Ensuring all dependencies that this engagement may have on other The Client projects is planned and met.
- The Client is to provide a minimum of ten working days' notice prior to agreed resource schedule commencement.
- The Client cannot cancel planned activities on this schedule during the three working days prior to starting those activities. If so, The Client will incur the full cost of the cancelled activities during that three-day period.

Authors

Name	Role
N/A	Technical Architect
[AM NAME]	Account Manager
Justin Towle	Head of Professional Services
Mike Bellido	Technical Architecture Director
Nick Johns	Chief Technical Officer
Adrian Sweeney	Chief Commercial Officer

Planet IT Contact Details

Method	Details	Method	Details
Telephone	01235 433900	Fax	+44 (0) 1235 433901
Email	architecture@planet-it.net	Address	Planet IT Ltd 85f Park Drive Milton Park Abingdon Oxfordshire OX14 4RY

Revision Details

Revision	Date	Author	Comments
1.1	March 2025	Internal authors	Updated for 2025
2.0		N/A	
2.1		[APPROVER NAME]	Internal Approval

Distribution List

Name	Company
	Acme Corp

Disclaimer

Whilst every precaution has been taken in the preparation of this document, no responsibility is assumed for errors or omissions, nor is any liability assumed for loss or damage resulting from the use of the information it contains, to the extent such error or omission is a result of any information, data or documents provided to Planet IT by the Customer and relied on by Planet IT in the preparation of this document.



01235 433 900

85F Park Drive
Milton Park
Abingdon
OX14 4RY

www.planet-it.net

enquiries@planet-it.net

Confidentiality

All information within this document is given in the strictest confidence and is considered as Confidential Information and genuine commercially sensitive information. With regards to this all parties shall treat information detailed in the strictest confidence and shall not, without the prior consent of the other party, disclose any information with regards to this proposal to any other organisations, whosoever they may be. In the event the customer is compelled by law or by any applicable regulatory agency (including a request to disclose information in accordance with the Freedom of Information Act 2000) to disclose any Confidential Information the customer shall immediately consult with Planet IT Limited prior to any such pending disclosure so that the parties may discuss whether the Confidential Information is exempt from disclosure or so that a protective order or other appropriate remedy may be obtained. If such an order or other remedy is not available, the customer shall disclose only that minimum portion of Confidential Information that it is legally compelled to disclose, consistent with the advice of its counsel.

Disclaimer

Planet IT Limited makes no representations or warranties with respect to the contents or use of this document, and specifically disclaims any express or implied warranties of merchantability or fitness for any purpose.

Intellectual Property

Nothing in this document is intended to grant any rights under any patent, copyright or other intellectual property right of Planet IT Limited